

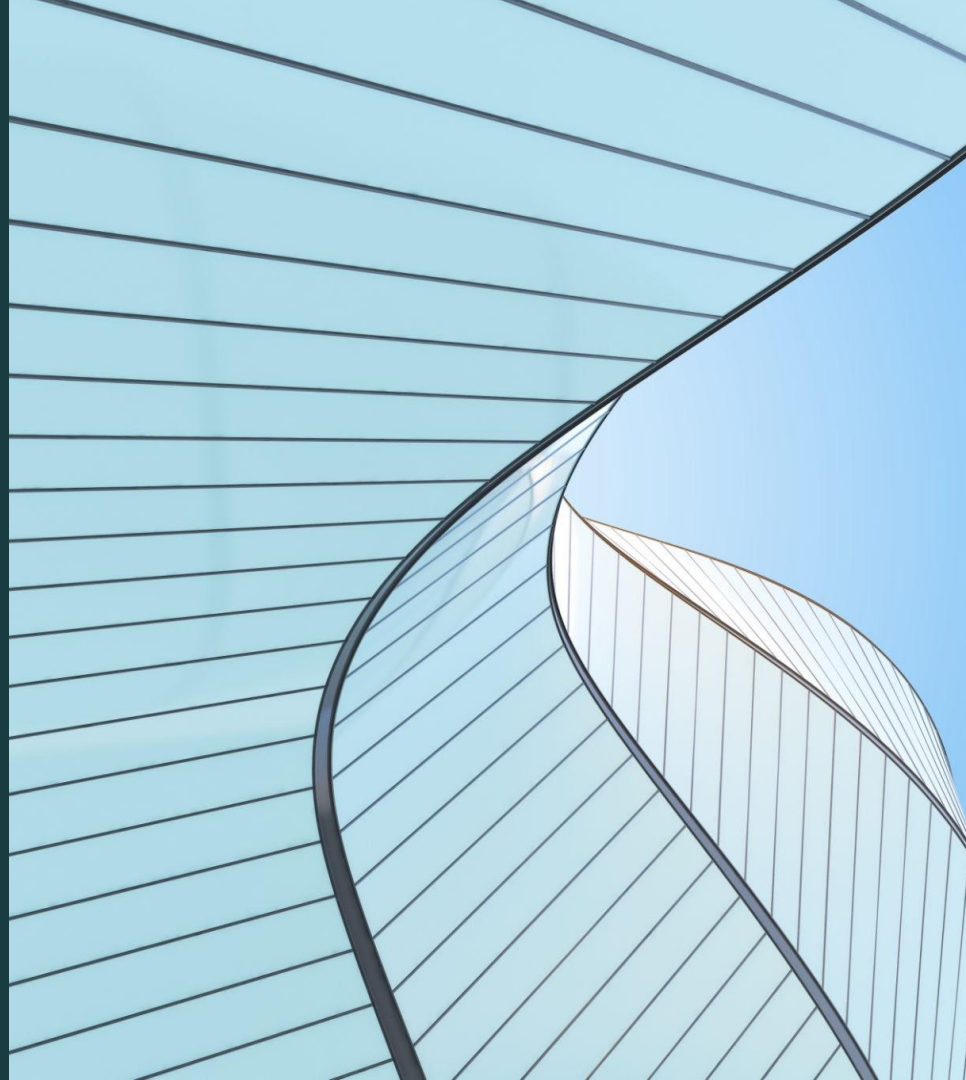
ICML 2025
July 15th

Taming the Wild West of ML

*From Model to Trust:
Building upon tamper-proof
ML metadata records*



Mihai Maruseac
GOSST
mihai.page

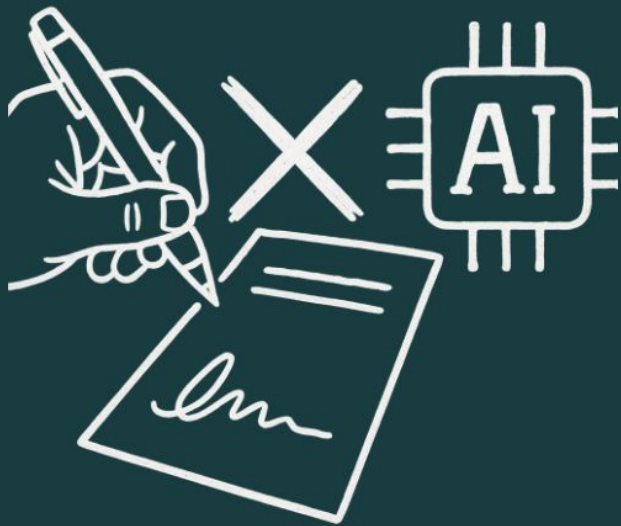


Two years ago..

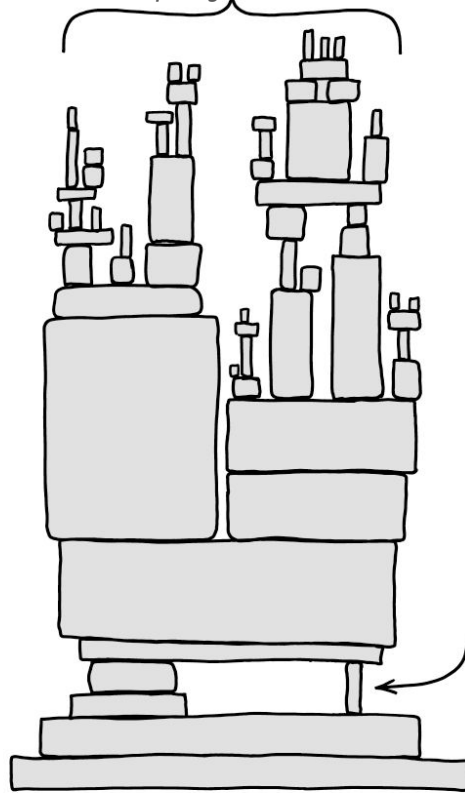
Future -> Reality

Models began to proliferate, be shared, and used widely

But... *there was a problem...*



*All super awesome &
cool AI projects*



XKCD 2347 (Kinda)

Initial training

Fine-tuning

Deploy



ML Developer 1



ML Developer 2



SWE

Train
Foundation
Model



Public/Private
Model Hub

Train
Fine-tuned
Model



Internal Model
Hub

Deploy Model
into Application

TikTok owner sacks intern for allegedly sabotaging AI project

ByteDance dismissed person in August it says 'maliciously interfered' with training of artificial intelligence models



∞ meta-llama / **Meta-Llama-3-8B** 

 Text Generation  Transformers  Safety

 **Model card**  Files and versions  xet

∞ facebook-llama / **Meta-Llama-8B** 

 Text Generation  Transformers  Safety

 **Model card**  Files and versions 

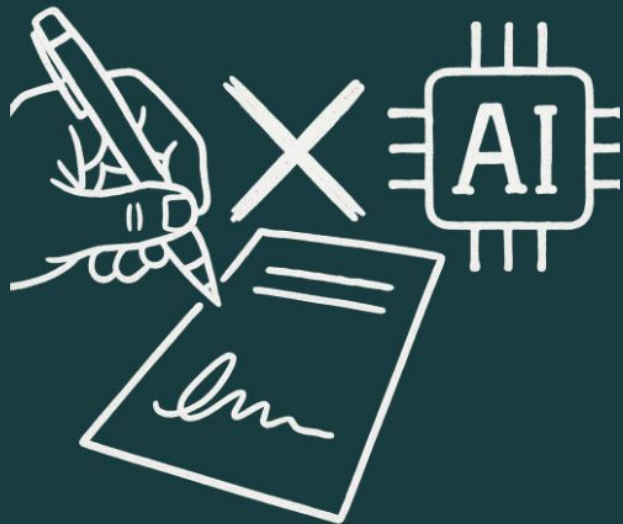
Two years ago..

Future -> Reality

Models began to proliferate, be shared, and used widely

There was no way to verify *trust* or *integrity*

Traditional approaches wouldn't work



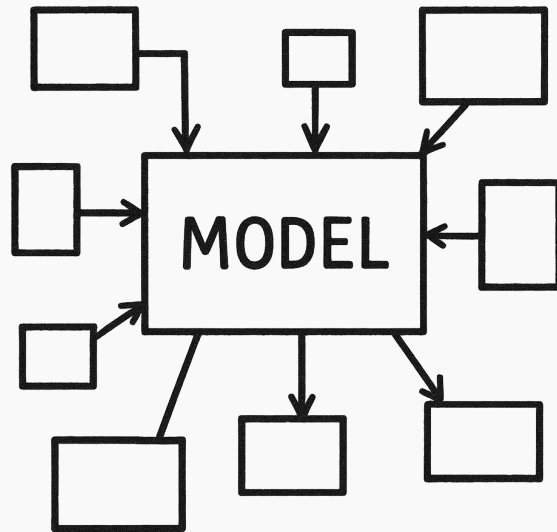
What's different with models?

Models aren't just a singular file..

Models aren't just one file format..

Fine-tuning means weights change..

You may not need all files in a model!



Questions we sought to answer

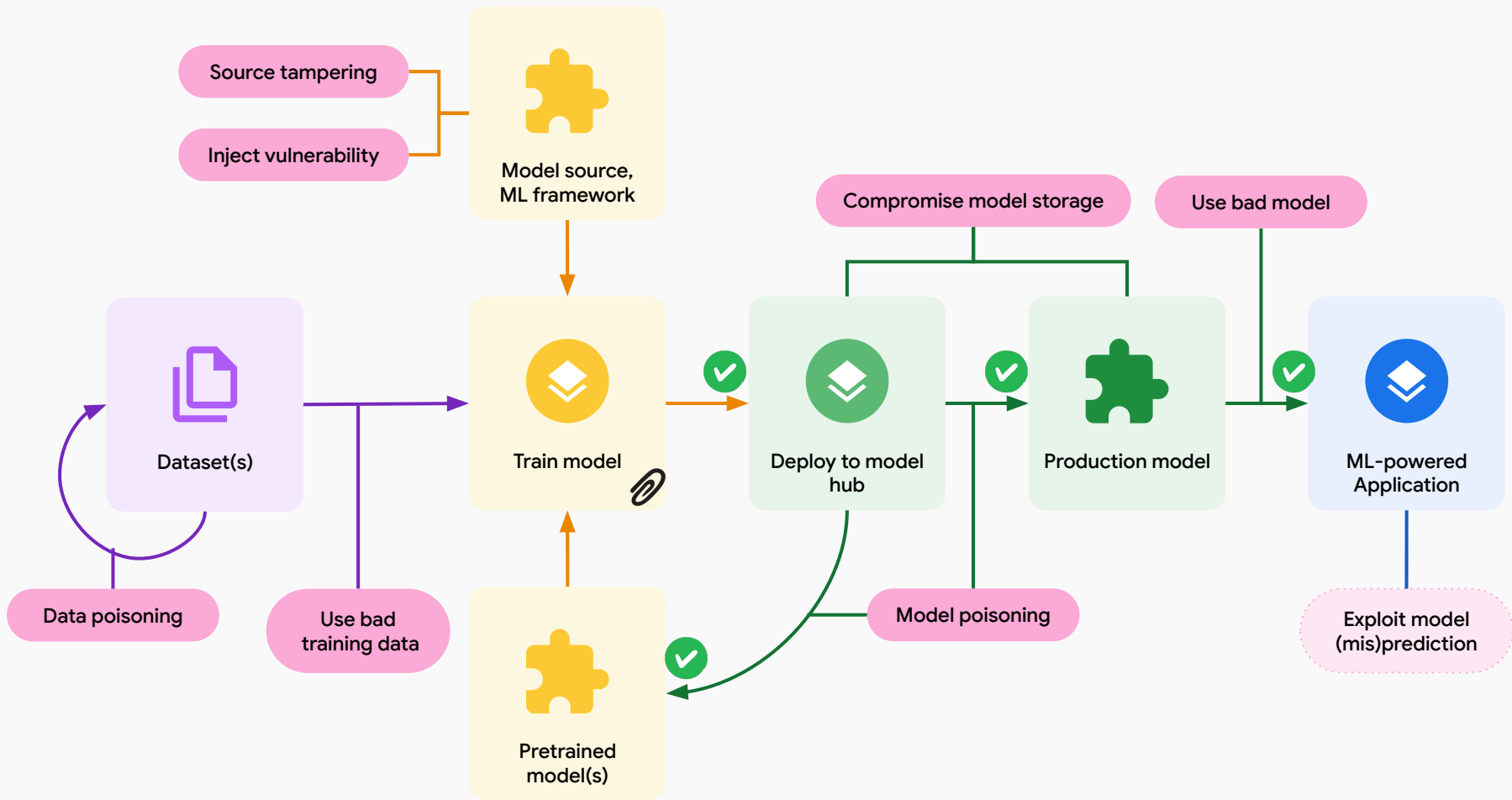


Who **trained** the model you're using?

Has it been **fine-tuned** since?

Has it been **tampered** with?

Can you **prove** it?



Today

AI is now an intrinsic part of our tech stack.

Signing and verification is finally here.

Signing builds towards provenance, traceability and compliance.

We need to drive adoption.



Launch of Model Signing v1.0:

OpenSSF AI/ML Working Group Secures the Machine Learning Supply Chain

An Introduction to the OpenSSF Model Signing (OMS) Specification

Model Signing for Secure and Trusted AI Supply Chains



OpenSSF Model Signing Format (OMS)

Signs collections of arbitrary files

Private Key Infrastructure Agnostic

- Sigstore
- Self-signed certificates
- Key pairs from PKI providers.

Provable integrity and trust in the AI Supply Chain.



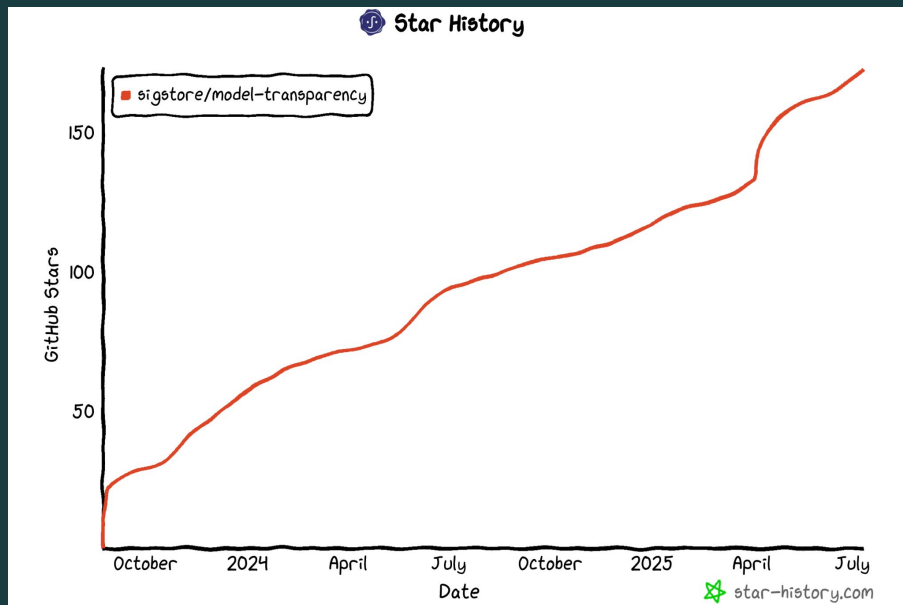
OMS Specification Announcement Blog

Sign today!

CLI & Library (in QR)

Available on PyPi:

```
pip install model-signing
```



173

GitHub stars

36

GitHub forks

285

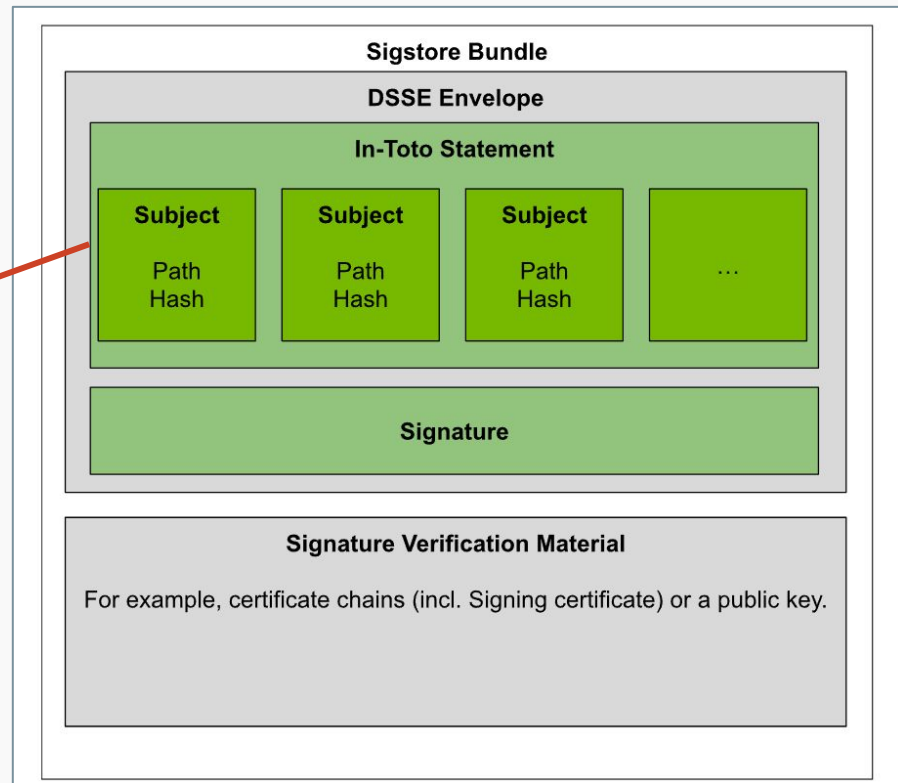
PyPI users



```

{
  "mediaType": "application/vnd.dev.sigstore.bundle.v0.3+json",
  "verificationMaterial": {
    "certificate": {
      "rawBytes": "MIIC1j..."
    },
    "tlogEntries": [
      {
        "logIndex": "250322532",
        ...
      }
    ],
    "dsseEnvelope": {
      "payload": "ewogIC..."
      "payloadType": "application/vnd.in-toto+json",
      "signatures": [
        {
          "sig": "MEUCIB..."
        }
      ]
    }
  }
}

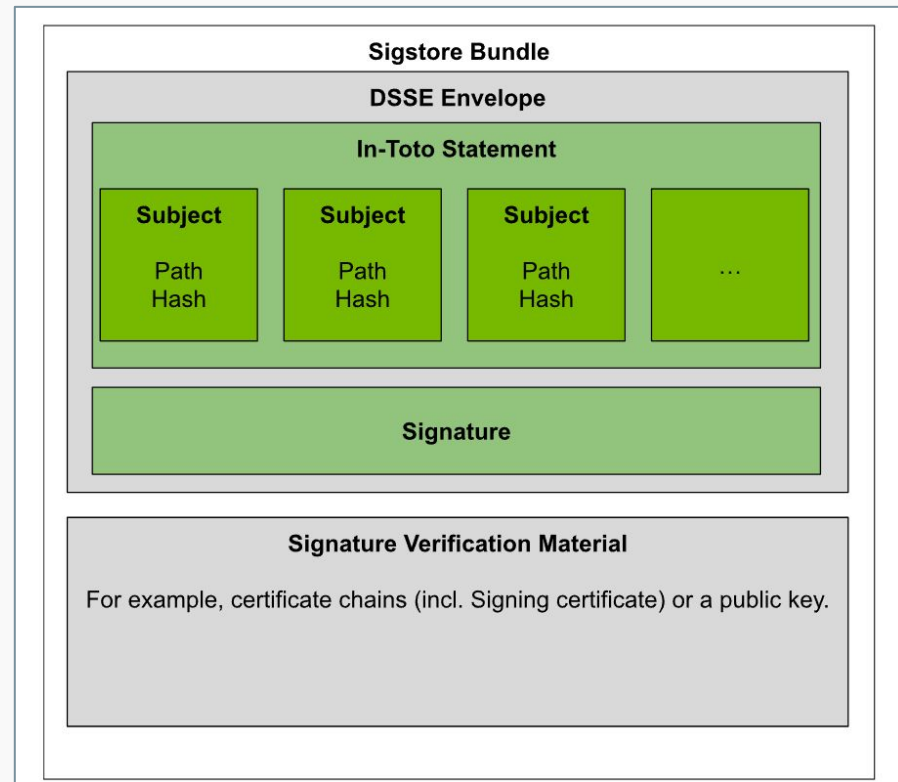
```



```

{
  "_type": "https://in-toto.io/Statement/v1",
  "subject": [
    {
      "name": "my_llm",
      "digest": {
        "sha256": "f8c499e..."
      }
    }
  ],
  "predicateType": "https://model_signing/signature/v1.0",
  "predicate": {
    ...
  }
}

```



```
{
  "resources": [
    {
      "digest": "54c13daffd7...",
      "algorithm": "sha256",
      "name": "weights.000001"
    },
    ...
  ],
  "serialization": {
    "method": "files",
    "hash_type": "sha256",
    "allow_symlinks": false
  }
}
```

```
{
  "resources": [
    {
      "digest": "54c13daffd7...",
      "algorithm": "sha256",
      "name": "weights.000001:1000:2000"
    },
    ...
  ],
  "serialization": {
    "method": "shards",
    "hash_type": "sha256",
    "shard_size": 1000,
    "allow_symlinks": false
  }
}
```

```
{
  "resources": [
    {
      "digest": "54c13daffd7...",
      "algorithm": "sha256",
      "name": "weights.000001"
    },
    ...
  ],
  "serialization": {
    "method": "gpu_hash",
    "hash_type": "sha256",
    ...
  }
}
```

```
{
  "resources": [
    {
      "digest": "54c13daffd7...",
      "algorithm": "sha256",
      "name": "weights.000001"
    },
    ...
  ],
  "model_card": {
    ...
  }
}
```

IDEAL FUTURE

All claims about ML models, datasets and metadata are tamper proof, tied to an identity, and automatically generated by the tools commonly used ML by developers.

Extend signing adoption

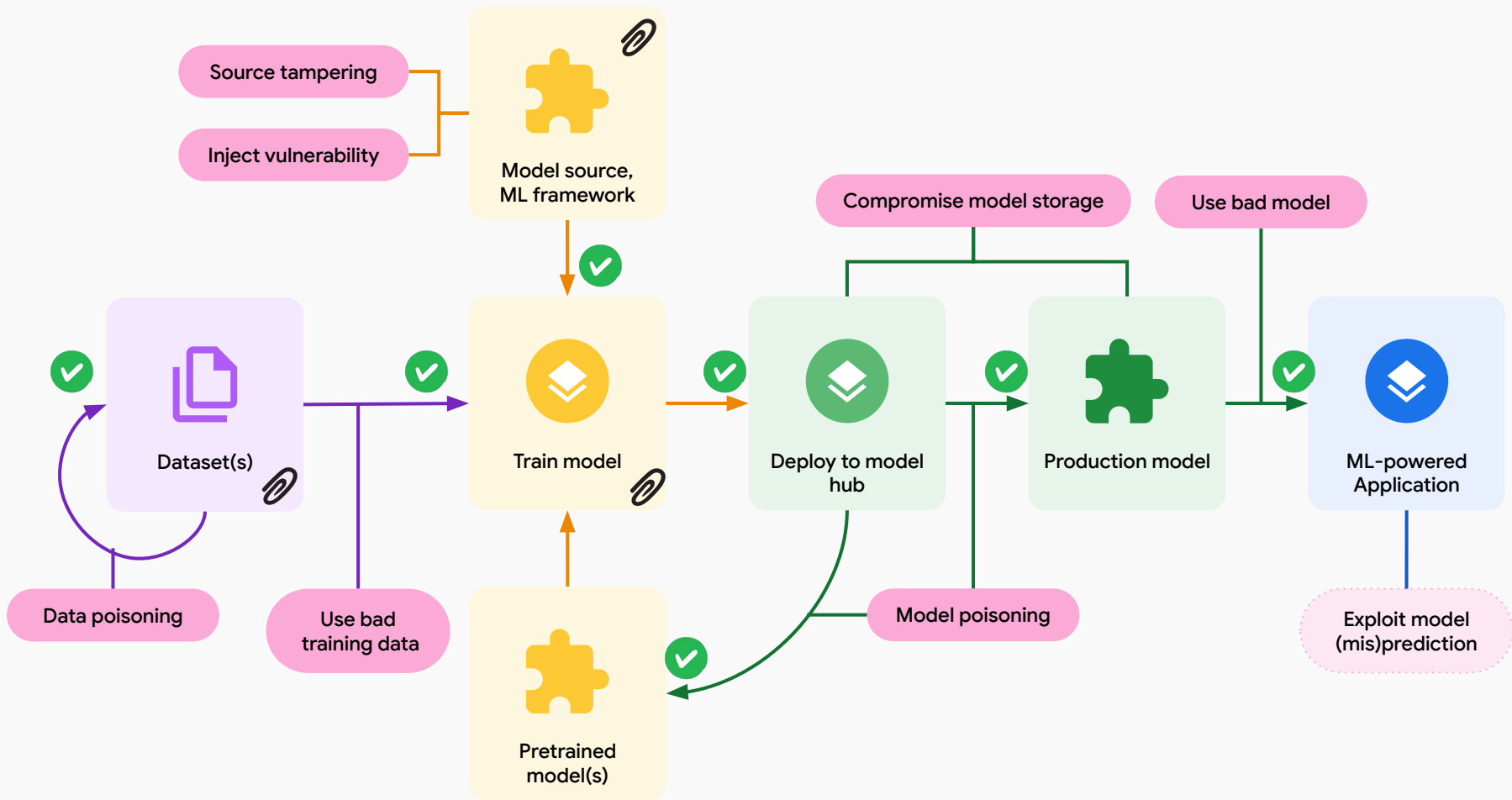
Datasets, model hub, model frameworks, ML pipelines, agents and agent cards

ML supply chain transparency

SLSA for ML, secure model trainers, ML package managers, automatic model and dataset lineage/provenance

Tamper proof ML metadata

From secure signature to automatic generation of AI-BOM and automation of incident response using GUAC/Trustify for AI



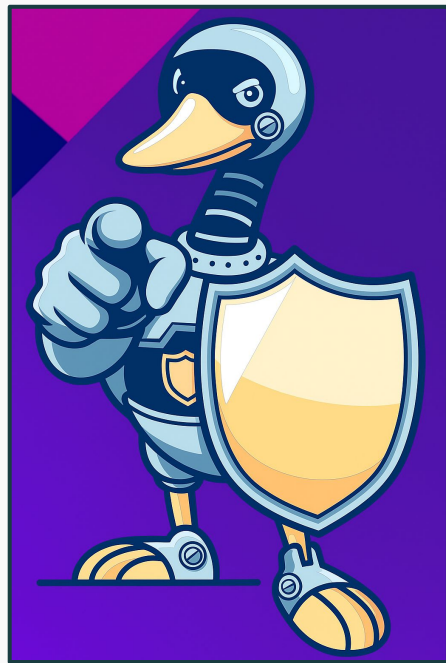
Help Secure the AI Supply Chain

We need you!

- OpenSSF AI/ML Working Group
Model Signing Project
- Coalition for Secure AI Workstream 1
Model Signing SIG

Help shape our roadmap, and get involved!

Next meeting at 1pm EST July 14th @ AI/ML Working Group



Let's ensure today's intelligent creations don't become tomorrow's security nightmares.

Thank you!

Special thanks to the contributors driving this effort forward, including Daniel Major, Martin Sablotny, Laurent Simon, Rich Harang, and the many others at Google, HiddenLayer, NVIDIA, Red Hat, Intel, Meta, IBM, Microsoft, and in the Sigstore, Coalition for Secure AI, and OpenSSF communities.